Security, costs, and ownership

How the FASTR platform protects a country's data — and what it takes to run it

FASTR Useful Data

Data security

What the platform holds

- **Monthly service totals per facility** — for example, 45 first antenatal visits at one clinic in March
- The **same figures as the DHIS2 reports** the ministry already produces
- **No patient records** — no names, no addresses, nothing individual

What "secure" means for a platform like this

In software and data hosting, security is not one thing — it is five. The next slides take them one at a time: the risk, then what answers it.

"Is it secure?" covers five distinct questions

Confidentiality
Only authorized people see the data
Who can access it?

Integrity
Figures cannot be altered unnoticed
Can the numbers be trusted?

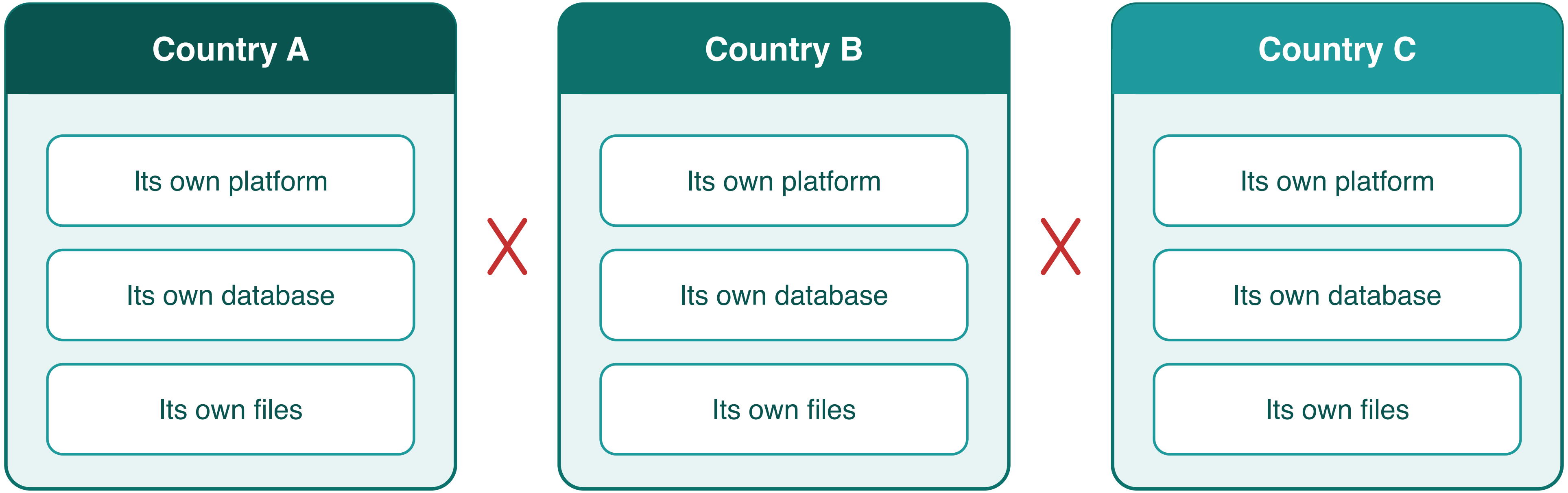
Availability
Accessible when needed
What happens if a server fails?

Sovereignty
Remains under national control
Who ultimately holds the data?

Accountability
Every action is logged
Who did what, and when?

Could our data leave the country's control?

Sovereignty. The risk: data flowing into a shared pool, or visible to another country. The answer: there is no shared pool — each country runs its own installation, sharing is technically impossible, and everything can be exported in full at any time.



No connection between countries — by design

Could someone gain unauthorized access?

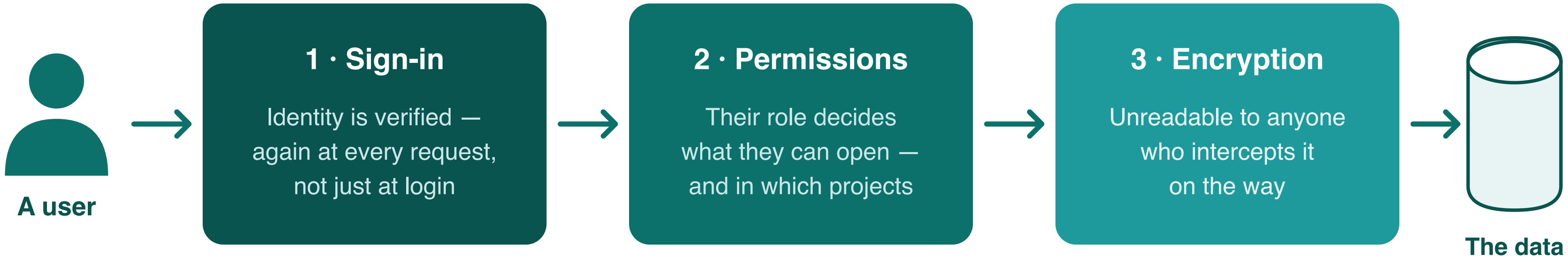
Confidentiality. The risk: a leaked password, or an insider reaching beyond their role. The answer: accounts, roles, and identity re-checked at every single request.

- The ministry decides **who gets an account**, and each person's role
- Roles set what a person can do — **view, edit, or administer** — and in which projects
- Identity is **re-checked on every request**, not just at login
- Only a **small, named group of administrators** can change the setup

Could data be intercepted — or lost?

Confidentiality and availability. The risk: interception on the network, or a server failure taking the data with it. The answer: nothing readable leaves the platform, and automatic copies mean everything can be rebuilt.

Three checks stand between a user and the data



Separately: protection against loss

The database is backed up every 30 minutes, the full installation daily — if a server fails, everything can be rebuilt

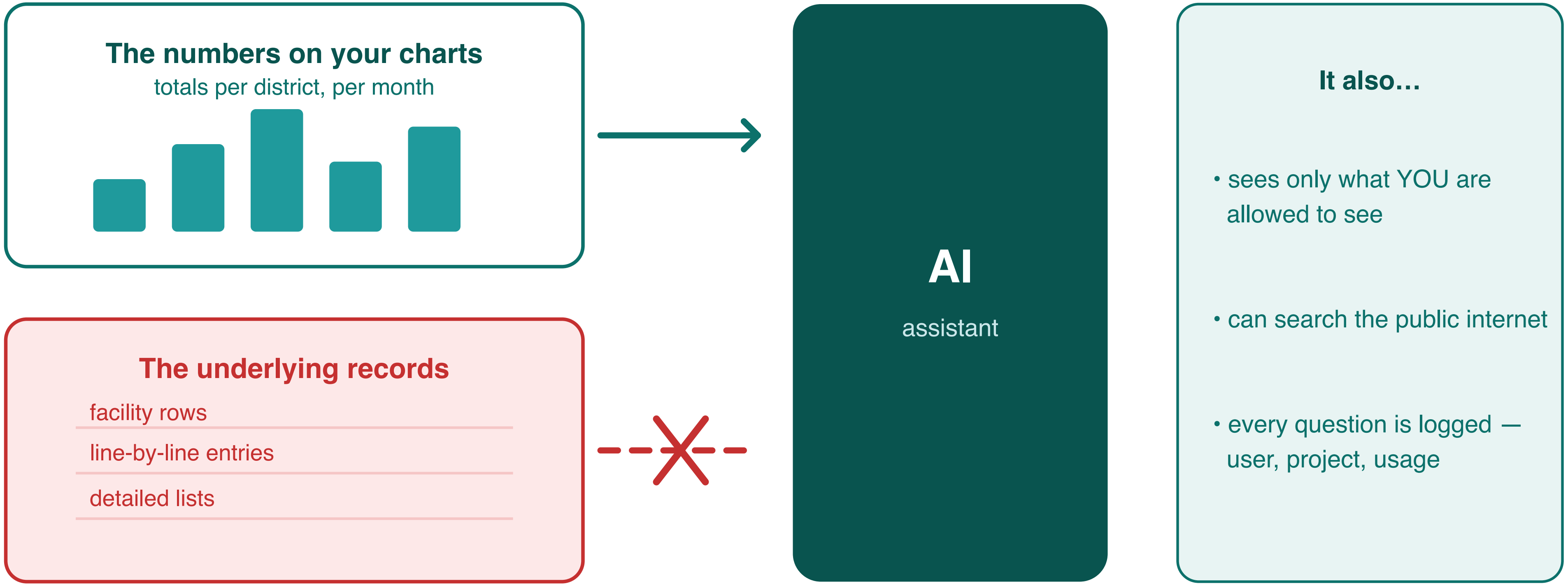
Could the figures be altered?

Integrity. The risk: figures altered without record, or analyses that cannot be reproduced. The answer: one source of truth, recorded imports, versioned results.

- **DHIS2 remains the source of truth** — the platform imports from it, and re-imported months are refreshed to match it
- **Every import is recorded**: an indicator-by-indicator ledger shows the months loaded, when, and any failures
- **Results come in versioned, dated packages** — the same package gives the same numbers to everyone; new numbers require a new package
- Analysis methods and parameters are **documented and logged with each package**

Could the AI expose what it sees?

Confidentiality and accountability. The risk: an assistant that sees too much. The answer: it is handed aggregated totals only — the numbers a user could already see, within that user's own permissions, and every question it is asked is logged. **Never the underlying rows.**



Costs and ownership

Running costs

Three lines: **server hosting** (fixed), **AI use** (metered), **maintenance** (shared team). No license fees, no per-user fees — the software is open source.

Hosting	AI assistant	People
Like rent	**Like electricity**	**Like maintenance**
A fixed monthly amount for the country's server	Metered — you pay only for what people use	Updates, monitoring, backups, user support
≈ USD 500–800 / year	**≈ USD 350 / month**	**≈ USD 7–10k / year, shared**

Planning estimates, 2026 prices — no license fees, no per-user charges

The figures — planning estimates

Estimates at 2026 prices and today's usage. **Not a quote.**

- **Hosting** a country's instance: about **USD 500–800 per year** — larger countries toward the top
- **AI use**: about **USD 350 per month** (~USD 4,000 per year) for a typical country; the largest countries several times this, and it grows with use
- **Shared platform maintenance** (engineering, monitoring, backups): roughly **USD 7,000–10,000 per country per year** today — it falls as more countries join
- **Optional support** (data refresh, quality checks, analysis): about **USD 5,000–15,000 per year**, depending on level
- **Total: about USD 12,000 per year** — up to USD 20,000–30,000 with support
- The lines include the external services: the **login service (Clerk)** and the **AI API (Anthropic)** — no hidden subscriptions
- **Economies of scale are already working**: one team and one codebase serve every country, so the per-country maintenance share falls as more countries join — economics a country gives up by hosting alone

Hosting — and what moving really takes

- Hosted **centrally today**, while the platform is in active development — every country receives fixes and new features the same day
- Built **portable**: the same software runs unchanged on a ministry's own servers — no rebuild needed
- **But migration is a project, not a switch**: readiness assessment, server procurement, team training, a parallel-run period, then cutover — measured in **months, and planned jointly**
- **And hosting alone means carrying alone** what is shared today: maintenance, monitoring, upgrades, and same-day fixes become the ministry team's own workload
- **All of a country's data can be exported in full at any time**, now or later, regardless of hosting

The path to country ownership

For countries who do want to host themselves, there will be effort required from the Ministry of Health. A team will need to run servers, backups, and upgrades; and procurement in place for hosting and for AI services, which are bought from a commercial provider (e.g. Anthropic, OpenAI).

Today

Hosted centrally while the platform is built out

Next

Ministry teams run users, data imports and updates

Goal — 2030

Hosted and managed by the country

end of GFF strategy period

What a country needs to take over

A server (its own or rented in the cloud) · an IT team to look after it · a budget for hosting and AI use

The essentials

- **Monthly totals only** — never patient records
- **One installation per country** — no pathway between countries
- **About USD 12,000 per year** to run — hosting, metered AI, shared maintenance; no license or per-user fees
- **Country hosting by 2030** — the stated transition goal

Technical annex — for IT and DHIS2 teams

Architecture and isolation

- Each country instance is a **separate Docker deployment**: its own application container, its own **PostgreSQL** database, its own **Valkey** cache, its own storage volume, on a private network
- Within an instance, each project has its **own database** (`project_{uuid}`) for authoring content
- Computed results live in **versioned results packages** (parquet files, queried via DuckDB) — projects read the package attached to them, never each other's

Authentication and access control

- Identity is managed by **Clerk** (managed identity provider); session claims are **verified by middleware on every request** — auth bypass exists only for local development and is disabled in production
- **Two-tier RBAC**: instance-level permissions plus per-project roles resolved from the database on each request
- Server access: **SSH by cryptographic key only**, restricted to two named engineers — no password login

Data protection and operations

- **TLS terminates at nginx**, certificates provisioned and auto-renewed via certbot; secrets are injected as environment variables at runtime — never in images, never sent to the browser
- **R analysis modules run in ephemeral containers** (removed on completion) that mount only their own run's sandbox directory
- Backups: **pg_dump every 30 minutes** (3-day rolling window) plus **volume snapshots daily / weekly / monthly**; restores are permission-gated (`can_restore_backups`) and require a server-held key on top of a valid session

AI integration, precisely

- Claude (Anthropic) is reached through a **server-side proxy**; the API key never leaves the server
- Tool calls run **inside the user's authenticated session** — the AI holds no permissions of its own
- Data tools return **aggregated metric outputs only**: there is **no facility-identifier dimension** in the query interface, and any dimension with more than 20 values is summarized as a count
- **Server-side web search/fetch (Anthropic-hosted) is enabled** in the project chat for general questions
- Every request is logged (user, project, model, tokens); **daily per-user and weekly per-instance limits** are enforced

Data and interoperability

- Source data: **aggregated DHIS2 numerators** (facility-month service counts) — imported server-side, with per-(indicator, month) replace semantics and a per-indicator import ledger
- **Full export at any time**: a country's data and results can be exported regardless of hosting arrangement
- The codebase is **open source**: github.com/FASTR-Analytics/platform